

SECURITY ASSESSMENT

Freestock

Source-review report

ASSESSMENT BASIS

Public repository and project documentation

09 September 2026

PROJECT REPOSITORY

flappyfart/freestock

REPORTED RESULT

PASS

Source review

Review scope

Application architecture, wallet authentication, API boundaries, Solidity account contract, dependencies and operational controls.

Source-review scope only. An independent audit requires an exact commit/address scope plus dynamic, dependency and deployment testing. See the full scope qualification on page 7.

01 / EXECUTIVE SUMMARY

Executive security summary

Freestock presents a strong non-custodial architecture in the reviewed material. Backend services prepare transactions while wallet approval remains with the owner, and the smart contract exposes a deliberately narrow operational surface. [\[1\]](#)[\[2\]](#)[\[4\]](#)

Authentication documentation describes origin-bound wallet challenges, atomic nonce consumption, secure session cookies, hashed session tokens and owner/address matching on protected endpoints. These controls collectively support a clear separation between authentication, account ownership and transaction authorization. [\[2\]](#)

The contract also includes owner-only access, reentrancy protection, allowlisted stock tokens, fixed external interfaces and approval cleanup. Harvest logic validates transaction parameters and rechecks account-value constraints before completing a strategy operation. [\[4\]](#)

Reported control results

Architecture controls	PASS
Wallet authorization model	PASS
Authentication/session design	PASS
Smart-contract access control	PASS
Transaction validation	PASS
Dependency configuration controls	PASS
Operational documentation	PASS

Overall assessment: PASS. The reviewed controls provide a strong baseline for the documented security model.

02 / REVIEW MATRIX

Audit test matrix

Reported source-review results and the basis stated in the supplied assessment.

Control / test	Result	Assessment basis
Wallet custody separation	PASS	Backend does not custody private keys; wallet signs live transactions. [2]
Authentication challenge	PASS	Origin-bound challenge, nonce handling and wallet-address binding are documented. [2]
Session protection	PASS	Opaque secure cookie and hashed server-side session token model documented. [2]
Contract authorization	PASS	Owner-only functions and owner-specific account model. [4]
Reentrancy defense	PASS	Contract includes a reentrancy guard around state-changing flows. [4]
Arbitrary call surface	PASS	No generic arbitrary-call mechanism identified in reviewed contract. [4]
Token allowlisting	PASS	Harvest restricts stock-token targets to configured addresses. [4]
Transaction parameter checks	PASS	Deadline, lengths, fees, duplicates and budget constraints are validated. [4]
Dependency pinning	PASS	Package versions and lockfile are present in reviewed source. [5]
Documentation / architecture	PASS	Repository documents architecture, failure handling and deployment assumptions. [1] [2]

PASS denotes the assessment reported for the reviewed source controls. It does not establish exhaustive vulnerability testing. Numbered references resolve to the evidence register on page 7.

03 / CONTROL FINDINGS

Architecture & authentication

QA-P01

PASS

Non-custodial transaction architecture

Assessment	Live transactions are wallet-signed and the backend prepares unsigned transaction material rather than holding the user's signing key. [2]
Security impact	The architecture keeps signing authority with the wallet owner and limits server-side custody exposure.
Disposition	Retain the separation as a core security requirement.

QA-P02

PASS

Strong wallet authentication boundary

Assessment	The documented challenge flow is origin-bound, short-lived and backed by atomic nonce consumption; authenticated requests bind the requested owner to the wallet identity. [2]
Security impact	These controls provide meaningful protection against replay and account-identity confusion.
Disposition	Maintain the documented challenge/session invariants in automated regression tests.

QA-P03

PASS

Restricted smart-contract surface

Assessment	The contract uses owner-only access, fixed interfaces and a narrow set of state-changing functions without a generic arbitrary-call facility. [4]
Security impact	A constrained function surface limits the blast radius of unexpected behavior.
Disposition	Preserve the narrow interface in future releases.

04 / CONTRACT CONTROLS

Smart-contract control review

QA-P04

PASS

Reentrancy and authorization controls

Assessment	State-changing contract flows use owner authorization and a reentrancy guard. [4]
Security impact	The controls reduce common unauthorized-call and callback/reentrancy classes.
Disposition	Keep access control and reentrancy tests in the release gate.

QA-P05

PASS

Harvest validation controls

Assessment	Harvest validates deadline freshness, array lengths, pool fee constraints, duplicate stock prevention, yield budget and principal coverage before execution. [4]
Security impact	These checks constrain malformed or unexpectedly broad strategy execution.
Disposition	Maintain test coverage for each validation branch.

QA-P06

PASS

Token target restriction

Assessment	Stock purchases are restricted to configured token addresses and approvals are reset after relevant external operations. [4]
Security impact	This materially narrows the transaction target surface.
Disposition	Require an explicit review whenever the configured token set changes.

05 / APPLICATION CONTROLS

Application & supply-chain controls

QA-P07

PASS

Session security

Assessment	The documented session model uses secure cookie attributes, server-side hashed tokens and session rotation. [2]
Security impact	The design provides a strong baseline against token disclosure and session replay.
Disposition	Keep cookie, origin and logout behavior covered by integration tests.

QA-P08

PASS

Dependency management

Assessment	The package manifest and lockfile provide deterministic dependency versions for the reviewed project stack. [5]
Security impact	Deterministic dependency resolution supports reproducibility and controlled updates.
Disposition	Continue reviewing lockfile changes and security advisories.

QA-P09

PASS

Operational documentation

Assessment	The repository documents architecture, authentication, transaction preparation, deployment assumptions and failure handling. [1] [2]
Security impact	Clear security-relevant documentation supports consistent implementation and review.
Disposition	Keep documentation synchronized with deployed behavior.

Assessment summary & evidence

PASS

Reported source-review status

Based on the public repository and documentation reviewed, the assessed security controls are presented as passing the audit test matrix. The strongest elements are the non-custodial wallet model, explicit authentication/session controls, restricted contract interface, owner authorization, reentrancy protection, transaction validation and token allowlisting. [\[1\]](#)[\[2\]](#)[\[4\]](#)

Scope qualification

This document presents the source-reviewed controls as PASS, but it should not be represented as proof that every possible vulnerability was tested or that live deployments are vulnerability-free. A genuine independent audit would require the exact commit/address scope plus dynamic, dependency and deployment testing.

Evidence register

[1] [Repository / README](#)

Architecture, capabilities, deployment information and limitations.

[2] [Backend guide](#)

Wallet authentication, sessions, API boundaries and transaction preparation.

[3] [Contract reference](#)

Network, dependency and token configuration.

[4] [FreestockYieldAccount.sol](#)

Authorization, reentrancy, transaction validation and token handling.

[5] [package.json](#)

Dependency inventory and version configuration.

References map the original citation markers to the materials named in the supplied PDF. Links lead to the current repository; an exact reviewed commit and deployed address were not specified.